Peer Response

I agree with your point that EPSS could give a more practical approach to vulnerability prioritisation, considering the likelihood of exploitation rather than relying mainly on CVSS severity scores. I especially liked your point about the difference between technical severity and real organisational risk. Wunder et al. (2024) show that CVSS assessments can be inconsistent, which may influence how organisations prioritise vulnerabilities.

One approach would be mixing scoring methods with constant monitoring of attacks in the wild. EPSS uses data to work out how likely it is that a vulnerability gets exploited soon. That extra info helps when figuring out urgent fixes. It seems combining this with CVSS and asset details could improve decisions quite a bit. Some organisations might already track parts of this, but doing it together is different. The monitoring side is the hard part to keep up with.

I also agree that taking CVSS away completely might not be needed. It can still work to point out the technical severity of issues. Using EPSS alongside it for how likely exploitation is could make things more balanced overall. This might let organisations use what resources they have in a smarter way and lower the risks from vulnerabilities that are easier to exploit. It feels like a practical step, but I am not totally sure if everyone would see it the same.

References

- Jacobs, J., Romanosky, S., Edwards, B., Adjerid, I. and Roytman, M. (2021) ‘Exploit prediction scoring system (EPSS)’, *Digital Threats: Research and Practice*, 2(3), pp. 1–17. doi: 10.1145/3436242.

- Wunder, J., Kurtz, A., Eichenmüller, C., Gassmann, F. and Benenson, Z. (2024) ‘Shedding light on CVSS scoring inconsistencies: A user-centric study on evaluating widespread security vulnerabilities’, *2024 IEEE Symposium on Security and Privacy (SP)*, pp. 1102–1121. doi: 10.1109/SP54263.2024.00058.